

Analizando logs de ataques Web com o wireshark

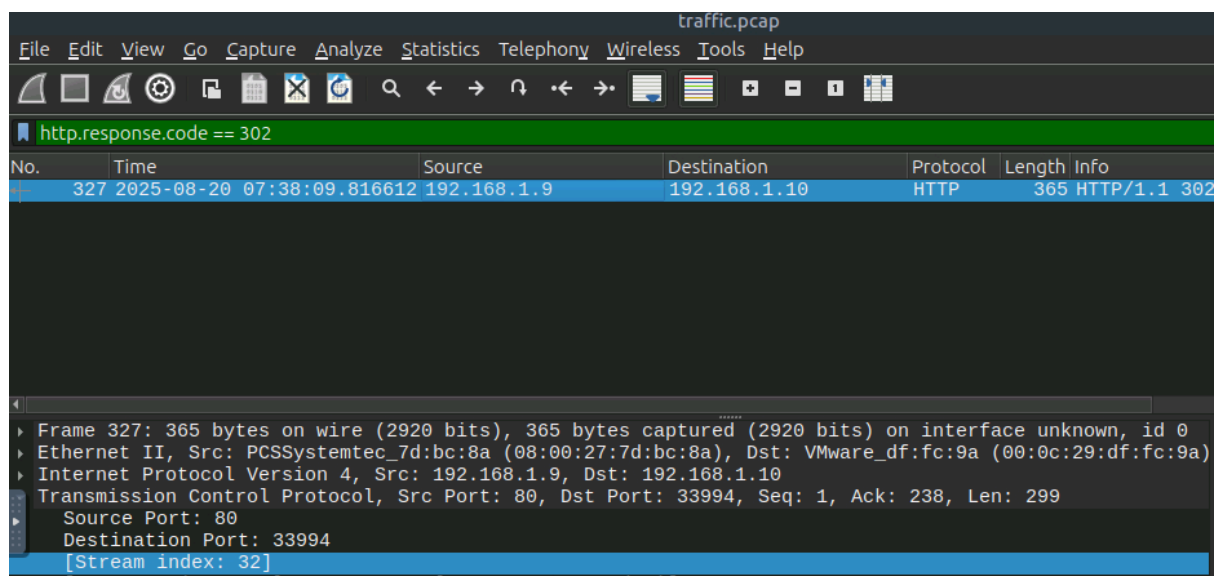
Investigação

O BankX, uma pequena plataforma de banco online, sofreu uma violação de segurança. Cibercriminosos invadiram o sistema e vazaram dados confidenciais de clientes em um fórum da darkweb. A administração acredita que a intrusão começou pelo site público da empresa, e cabe a mim descobrir exatamente como isso aconteceu.

Minha missão é analisar os logs usando o wireshark e refazer os passos do invasor para revelar como a violação ocorreu. O arquivo que me foi passado foi: **traffic.pcap**.

1 - Qual senha o invasor identifica com sucesso no ataque de força bruta?

Iniciei usando um filtro no Wireshark: `http.response.code == 302`



Agora que descobri o índice irei usar esse comando para filtrar as requisições relacionadas a esse fluxo de TCP e investigar os detalhes do login: `tcp.stream == 32`

tcp.stream == 32						
No.	Time	Source	Destination	Proto		
316	2025-08-20 07:38:09.814090	192.168.1.10	192.168.1.9	HTTP		
322	2025-08-20 07:38:09.815245	192.168.1.9	192.168.1.10	TCP		
327	2025-08-20 07:38:09.816612	192.168.1.9	192.168.1.10	HTTP		
328	2025-08-20 07:38:09.816613	192.168.1.9	192.168.1.10	TCP		
329	2025-08-20 07:38:09.816666	192.168.1.10	192.168.1.9	TCP		
377	2025-08-20 07:38:09.857873	192.168.1.10	192.168.1.9	TCP		
400	2025-08-20 07:38:09.917264	192.168.1.10	192.168.1.9	TCP		
402	2025-08-20 07:38:09.918266	192.168.1.9	192.168.1.10	TCP		

Cliquei com o botão direito do mouse no pacote bem sucedido → Follow → TCP Stream

tcp.stream == 32

Time	Source	Destination	Protocol	Length	Info
07:38:09.813995	192.168.1.10	192.168.1.9	TCP	66	33994 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=2897328468...
07:38:09.814090	192.168.1.10	192.168.1.9	HTTP	303	POST /login.php HTTP/1.0 (application/x-www-form-urlencoded)
07:38:09.815245	192.168.1.9	192.168.1.10	TCP	66	80 → 33994 [ACK] Seq=1 Ack=238 Win=65024 Len=0 TSval=25633365...
07:38:09.816612	192.168.1.10	192.168.1.10	HTTP	365	HTTP/1.1 302 Found
07:38:09.816613	192.168.1.9	192.168.1.10	TCP	66	80 → 33994 [FIN, ACK] Seq=300 Ack=238 Win=65024 Len=0 TSval=2...
07:38:09.816666	192.168.1.10	192.168.1.9	TCP	66	33994 → 80 [ACK] Seq=238 Ack=300 Win=64128 Len=0 TSval=289732...
07:38:09.857873	192.168.1.10	192.168.1.9	TCP	66	33994 → 80 [ACK] Seq=238 Ack=301 Win=64128 Len=0 TSval=289732...
07:38:09.917264	192.168.1.10	192.168.1.9	TCP	66	33994 → 80 [FIN, ACK] Seq=238 Ack=301 Win=64128 Len=0 TSval=2...
07:38:09.918266	192.168.1.9	192.168.1.10	TCP	66	80 → 33994 [ACK] Seq=301 Ack=238 Win=65024 Len=0 TSval=256333...

Frame 402: 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on interface
Ethernet II, Src: PCSSystemtec_7d:bc:8a (08:00:27:7d:bc:8a), Dst: VMware_df:fc:9a
Internet Protocol Version 4, Src: 192.168.1.9, Dst: 192.168.1.10
Transmission Control Protocol, Src Port: 80, Dst Port: 33994, Seq: 301, Ack: 239,
Source Port: 80
Destination Port: 33994
[Stream index: 32]
[Conversation completeness: Complete, WITH_DATA (31)]
[TCP Segment Len: 0]
Sequence Number: 301 (relative sequence number)
Sequence Number (raw): 3839512847
[Next Sequence Number: 301 (relative sequence number)]
Acknowledgment Number: 239 (relative ack number)
Acknowledgment number (raw): 1660875745
1000 = Header Length: 32 bytes (8)
Flags: 0x010 (ACK)

Mark/Unmark Packet(s) Ctrl+M
Ignore/Unignore Packet(s) Ctrl+D
Set/Unset Time Reference Ctrl+T
Time Shift... Ctrl+Shift+T
Packet Comments
Edit Resolved Name
Apply as Filter
Prepare as Filter
Conversation Filter
Colorize Conversation
SCTP
Follow TCP Stream Ctrl+Alt+Shift+T

e o resultado aparece:

Wireshark · Follow TCP Stream (tcp.stream eq 32) · traffic.pcap

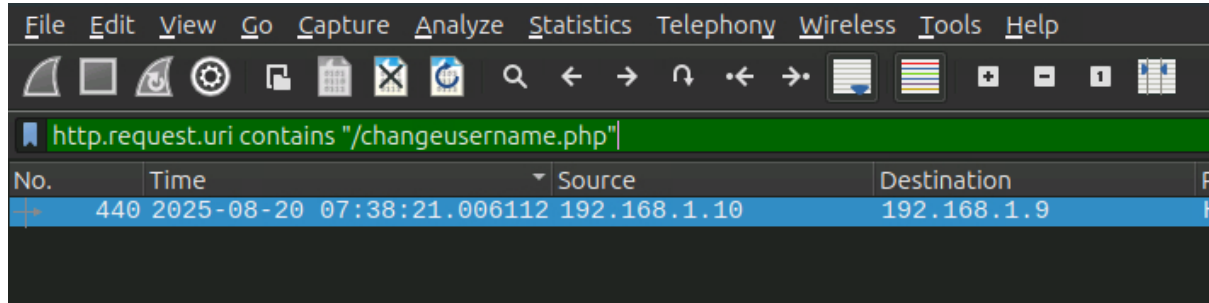
POST /login.php HTTP/1.0
Host: 192.168.1.9
User-Agent: Mozilla/5.0 (Hydra)
Content-Length: 42
Content-Type: application/x-www-form-urlencoded
Cookie: PHPSESSID=o137k6rt2ivjj8tdthlclfk7

username=admin&password=astrongpassword123HTTP/1.1 302 Found
Date: Wed, 20 Aug 2025 07:38:09 GMT
Server: Apache/2.4.52 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: /account
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8

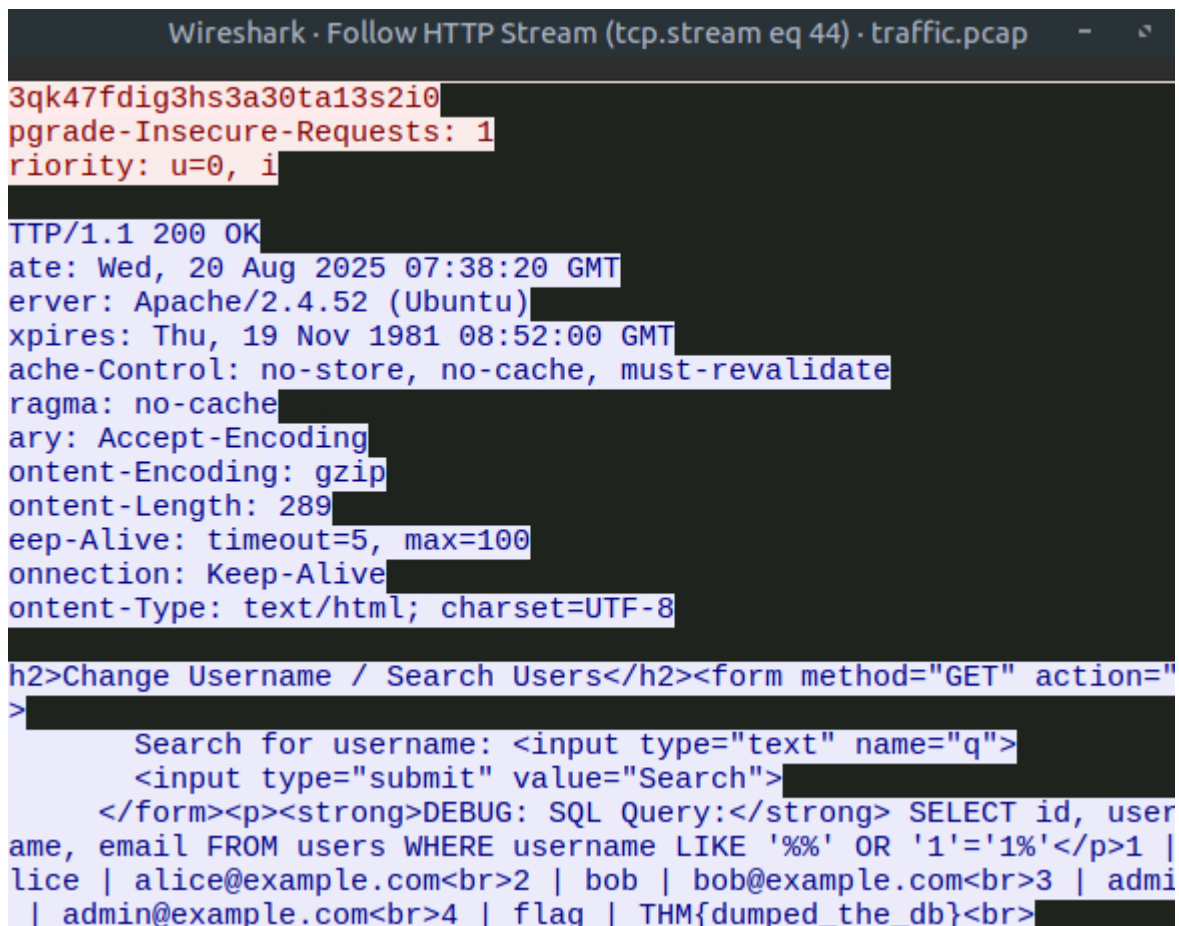
Resposta: **astrongpassword123**

2 - Qual é o sinalizador que o invasor encontrou no banco de dados usando SQLi?

Usei o filtro: `http.request.uri contains "/changeusername.php"`



Cliquei com o botão direito -> Follow -> HTTP Stream



Resposta: `THM{dumped_the_db}`



Autor: Paulo Cesar
Formado em Segurança da informação
[linkedin.com/in/paulo-cesar-security](https://www.linkedin.com/in/paulo-cesar-security)